

Burp Suite — The Web Tester's Toolkit

Burp Suite is the industry-standard tool for web application security testing. It sits between your browser and the server as a proxy, allowing you to intercept, inspect, modify, and replay every HTTP request. Used by penetration testers, bug bounty hunters, and CTF players worldwide.

6.1 Setting Up Burp Suite

Installation

- Download Burp Suite Community Edition from portswigger.net/burp — it is free
- Install FoxyProxy extension in your browser for easy proxy switching
- In FoxyProxy, add a proxy: 127.0.0.1 on port 8080

Browser Configuration

- Start Burp Suite and go to Proxy > Intercept
- Enable FoxyProxy to route through Burp
- Visit <http://burp> in your browser and download the CA certificate
- Install the CA certificate in your browser's trusted certificate store
- You can now intercept HTTPS traffic

6.2 Burp Proxy — Intercepting Requests

With Intercept turned ON, every request from your browser is paused and shown in Burp before being sent to the server. You can read it, modify it, then forward or drop it.

What You Can Modify

- URL parameters — change `?id=1` to `?id=2`
- POST body — change submitted form values
- Headers — add, remove, or modify any header
- Cookies — modify session tokens
- HTTP method — change GET to POST or vice versa

6.3 Burp Repeater — Replaying Requests

Repeater lets you send a captured request to a panel where you can modify it and resend it as many times as you want, observing the response each time. Essential for manual SQLi and XSS testing.

Workflow

1. In Proxy, right-click any request > Send to Repeater
2. Switch to the Repeater tab
3. Modify the request as needed
4. Click Send — observe the response on the right
5. Iterate — modify and resend until you find the vulnerability

6.4 Burp Intruder — Automated Fuzzing

Intruder automates sending many requests with different payloads. Used for brute force, fuzzing parameters, and testing lists of values.

Attack Types

Type	Use Case
Sniper	One payload position, one wordlist. Test a single parameter.
Battering Ram	Same payload in all positions simultaneously.
Pitchfork	Multiple positions, multiple wordlists — each in sync.
Cluster Bomb	Multiple positions, all combinations — brute force credentials.

Brute Forcing a PIN

1. Capture the login request in Proxy
2. Send to Intruder
3. Click Clear, then highlight the PIN value, click Add
4. Go to Payloads > Numbers from 0000 to 9999
5. Start Attack — watch for a response with different length or status code

6.5 Burp Decoder

Quickly encode and decode values in common formats:

Format	Example Use
Base64	Decode JWT payloads, cookie values, encoded parameters
URL encoding	Decode %3C%3E to <>, or encode payloads for URL injection
HTML entities	Decode < > back to < > for analysis
Hex	Inspect binary data, magic bytes, hashed values

6.6 Burp Scanner (Pro) / Active Scan

The Community edition includes a passive scanner that flags obvious issues. The Pro edition includes an active scanner that automatically tests for SQLi, XSS, and other vulnerabilities. For CTFs and learning, manual testing with Proxy and Repeater is more educational.